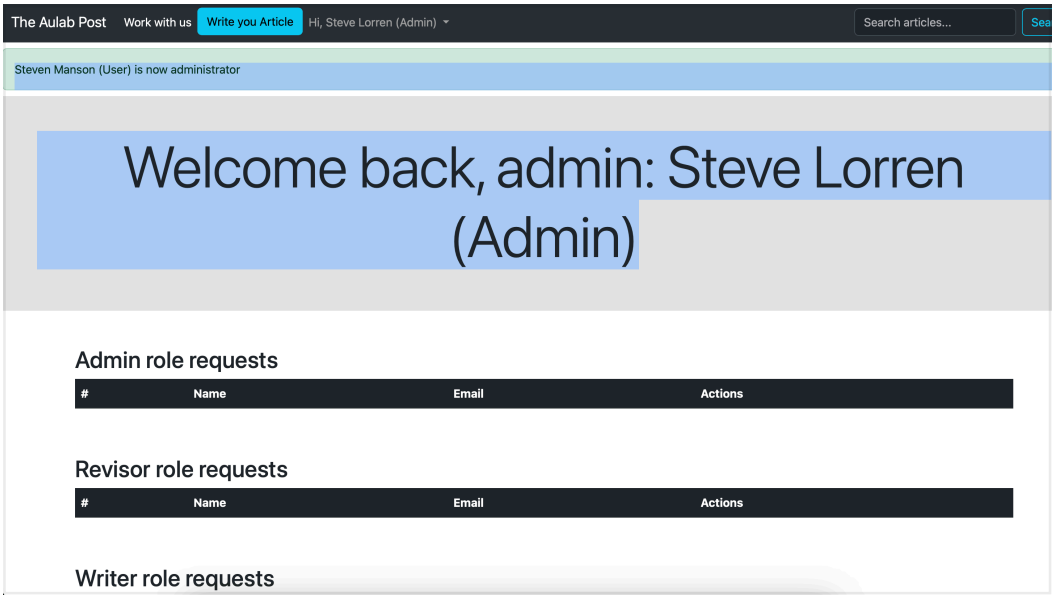
Challenge 2 (CSRF)

Alcune azioni importanti dell'admin (rendere un utente admin, revisor o writer) erano fatte con rotte in GET, cioè con un semplice link. In GET non c'è la protezione CSRF di Laravel, quindi una pagina malevola può far partire l'azione mentre l'admin è loggato.

Attacco riuscito-

Nella cartella XXX-AttackTools/csrf c'è una pagina HTML (index.html) che apre in automatico un link nascosto verso:
http://internal.admin:8000/admin/2/set-admin
Ho lasciato aperta la sessione da admin su internal.admin:8000 e ho aperto quella pagina HTML. L'utente con id 2 (Steven Manson) è diventato amministratore



Mitigazione-

Ho cambiato le rotte da GET a PATCH (set-admin, set-revisor, set-writer).
Nella vista admin ho sostituito i link "Enable …" con **form** che usano @csrf e @method('PATCH'). Così l'azione parte solo da un form legittimo della dashboard, non da un link GET esterno.

routes > web.php

```php
});

// Revisor routes
Route::middleware('revisor')->group(function(){
    Route::get('/revisor/dashboard', [RevisorController::class, 'dashboard'])->name('revisor.dashboard');
    Route::post('/revisor/{article}/accept', [RevisorController::class, 'acceptArticle'])->name('revisor.acceptArticle');
    Route::post('/revisor/{article}/reject', [RevisorController::class, 'rejectArticle'])->name('revisor.rejectArticle');
    Route::post('/revisor/{article}/undo', [RevisorController::class, 'undoArticle'])->name('revisundoArticle');
});

// Admin routes
Route::middleware(['admin','admin.local'])->group(function(){
    Route::get('/admin/dashboard', [AdminController::class, 'dashboard'])->name('admin.dashboard'
    Route::patch('/admin/{user}/set-admin', [AdminController::class, 'setAdmin'])->name('admin.setAdmin');
Route::patch('/admin/{user}/set-revisor', [AdminController::class, 'setRevisor'])->name('admin.setRevisor');
Route::patch('/admin/{user}/set-writer', [AdminController::class, 'setWriter'])->name('admin.setWriter');
    Route::put('/admin/edit/tag/{tag}', [AdminController::class, 'editTag'])->name('admin.editTag
    Route::delete('/admin/delete/tag/{tag}', [AdminController::class, 'deleteTag'])->name('admin.
```

resources > views > components > requests-table.blade.php

```blade
<table class="table table-striped table-hover">
    <tbody>
        @foreach ($roleRequests as $user)
            <tr>
                <td>{{$user->name}}</td>
                <td>{{$user->email}}</td>
                <td>
                    @switch($role)
                        @case('admin')
                            <form action="{{route('admin.setAdmin', $user)}}" method="POST">
                                @csrf
                                @method('PATCH')
                                <button type="submit" class="btn btn-secondary">Enable {{$role}}</button>
                            </form>
                            @break
                        @case('revisor')
                            <form action="{{route('admin.setRevisor', $user)}}" method="POST">
                                @csrf
                                @method('PATCH')
                                <button type="submit" class="btn btn-secondary">Enable {{$role}}</button>
                            </form>
                            @break
                        @case('writer')
                            <form action="{{route('admin.setWriter', $user)}}" method="POST">
                                @csrf
                                @method('PATCH')
                                <button type="submit" class="btn btn-secondary">Enable {{$role}}</button>
                            </form>
                            @break
                    @endswitch
                </td>
            </tr>
```

Attacco fallito (dopo mitigazione)-

Ho rifatto la stessa prova: admin loggato + doppio click su index.html.
Questa volta l'utente non è stato promosso. Laravel ha risposto con un errore: il

metodo GET non è supportato sulla rotta admin/2/set-admin (accettato solo PATCH) - MethodNotAllowedHttpException.

